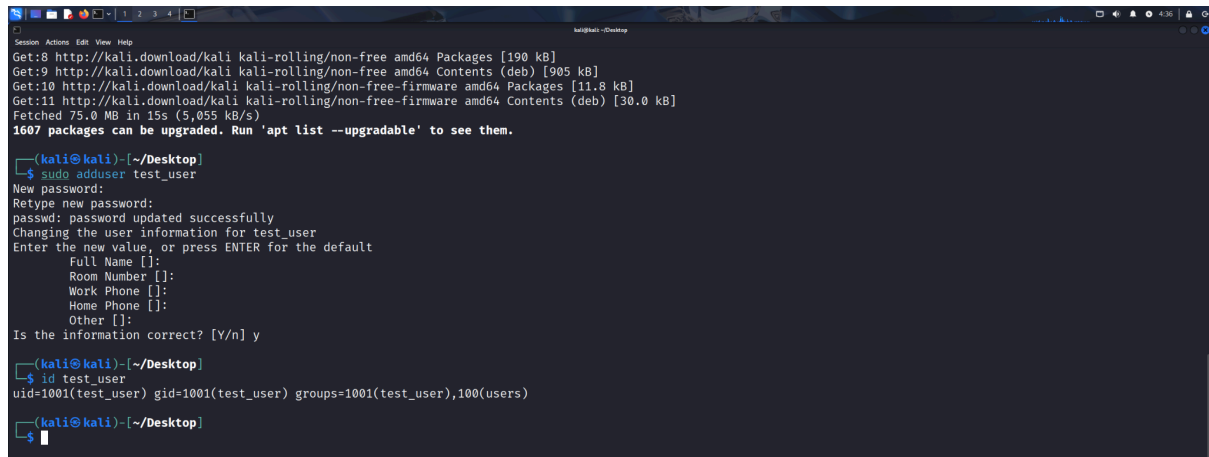


Authentication cracking con Hydra “ssh”

Nella prima fase di questo laboratorio ho creato un nuovo utente su Kali con il seguente comando:

sudo adduser test_user

Password: **testpass**



```
Get:8 http://kali.download/kali kali-rolling/non-free amd64 Packages [190 kB]
Get:9 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [905 kB]
Get:10 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [11.8 kB]
Get:11 http://kali.download/kali kali-rolling/non-free-firmware amd64 Contents (deb) [30.0 kB]
Fetched 75.0 MB in 15s (5,055 kB/s)
1607 packages can be upgraded. Run 'apt list --upgradable' to see them.

(kali@kali)-[~/Desktop]
$ sudo adduser test_user
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for test_user
Enter the new value, or press ENTER for the default
Full Name []:
Room Number []:
Work Phone []:
Home Phone []:
Other []:
Is the information correct? [Y/n] y

(kali@kali)-[~/Desktop]
$ id test_user
uid=1001(test_user) gid=1001(test_user) groups=1001(test_user),100(users)

(kali@kali)-[~/Desktop]
$
```

Poi ho usato il comando **ip test_user** per accertarmi che l'avesse creato. L'output:

1. uid=1001

- uid sta per **User ID**
- Ogni utente in Linux ha un numero unico (UID) che identifica quell'utente internamente al sistema.
- Nel nostro caso, 1001 è l'identificativo del tuo utente test_user. Questo numero viene usato dal sistema per capire i permessi, chi ha creato un file, ecc.

2.gid=1001

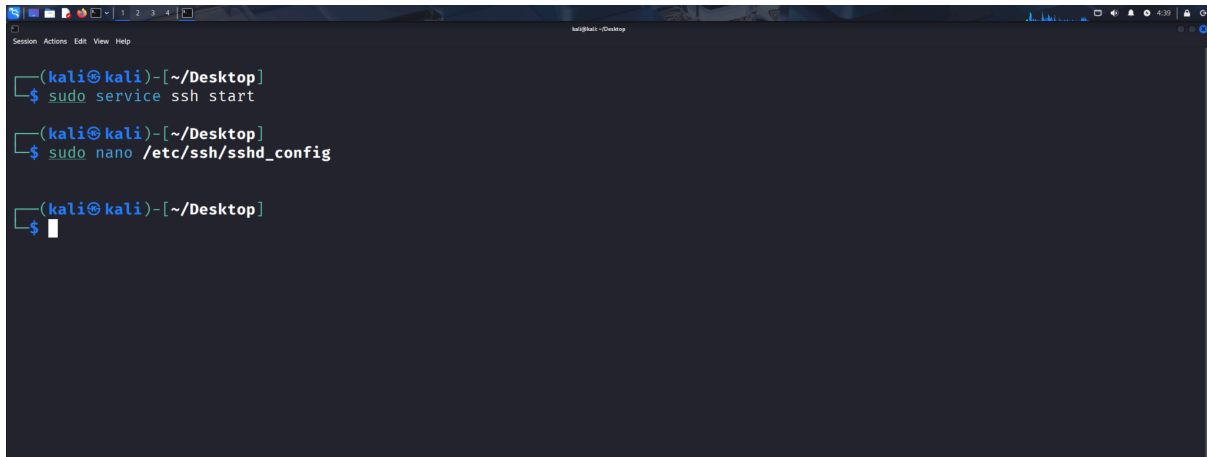
- gid sta per **Group ID principale**
- Ogni utente appartiene a un gruppo principale. Anche i gruppi hanno un numero identificativo univoco.
- Qui, gid=1001 indica che il gruppo principale di test_user ha ID 1001.

3.groups=1001

- Questa parte elenca tutti i gruppi a cui l'utente appartiene (non solo quello principale).
- In questo caso, l'utente test_user appartiene solo al gruppo con ID 1001
- Se l'utente fosse in più gruppi, vedremmo qualcosa tipo groups=1001,1002,1003

Abilitazione del servizio ssh.

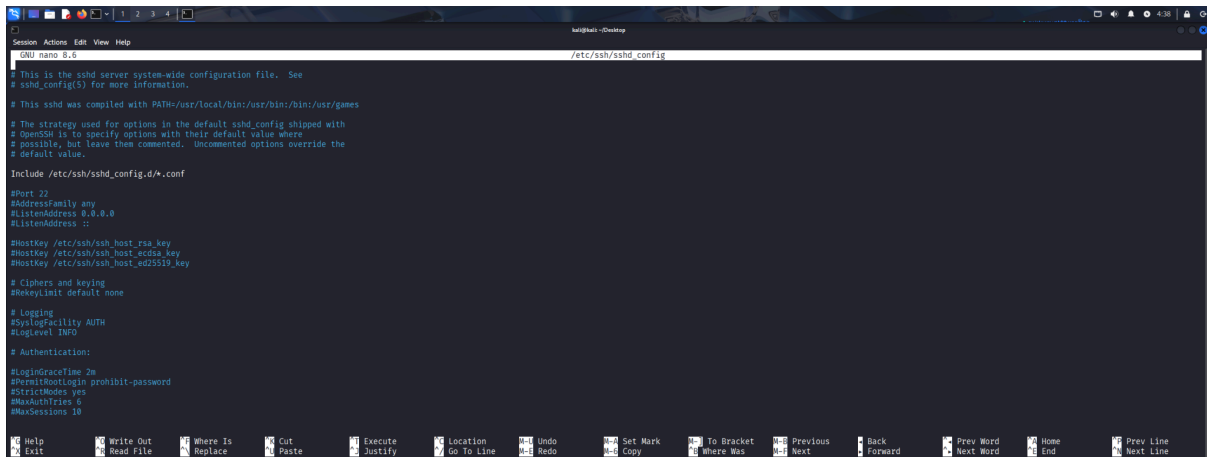
Col comando “**sudo service ssh**” ho abilitato il servizio ssh
e con “**sudo nano /etc/ssh/sshd_config**” sono entrato nel file di configurazione di ssh



```
(kali@kali)-[~/Desktop]
$ sudo service ssh start

(kali@kali)-[~/Desktop]
$ sudo nano /etc/ssh/sshd_config

(kali@kali)-[~/Desktop]
$
```



```
GNU nano 2.9.6 /etc/ssh/sshd_config
# This is the sshd server system-wide configuration file. See
# sshd_config(5) for more information.

# This sshd was compiled with PATH=/usr/local/bin:/usr/bin:/usr/games

# The strategy used for options in the default sshd_config shipped with
# OpenSSH is to specify options with their default value where
# possible, but leave them commented. Uncommented options override the
# default value.

Include /etc/ssh/sshd_config.d/*conf

#Port 22
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# GSSAPI and keying
#GSSAPIAuthentication no
#GSSAPICallbackRecord no
#GSSAPIKeyExchange no
#GSSAPIStrictModes yes
#GSSAPIUserKnownHostsFile /dev/null
#GSSAPISystemWideKnownHostsFile /dev/null
#GSSAPITrustedUserCAFiles /dev/null

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
#PermitRootLogin prohibit-password
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10
```

Testo la connessione in SSH dell'utente appena creato sul sistema

Per entrare con “ssh” ho eseguito il comando:

ssh test_user@192.168.50.100

```
(kali@kali)-[~/Desktop]
$ ssh test_user@192.168.50.100
The authenticity of host '192.168.50.100 (192.168.50.100)' can't be established.
ED25519 key fingerprint is SHA256:6abFjAzEgYmnJd1XxjFKvqNd0dzc/isp1yOmzNuGdE.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.50.100' (ED25519) to the list of known hosts.
test_user@192.168.50.100's password:
Linux kali 6.12.38+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.38-1kali1 (2025-08-12) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
(test_user@kali)-[~]
$
```

Ora per testare con Hydra ho creato due liste filtrate una di username e una di password

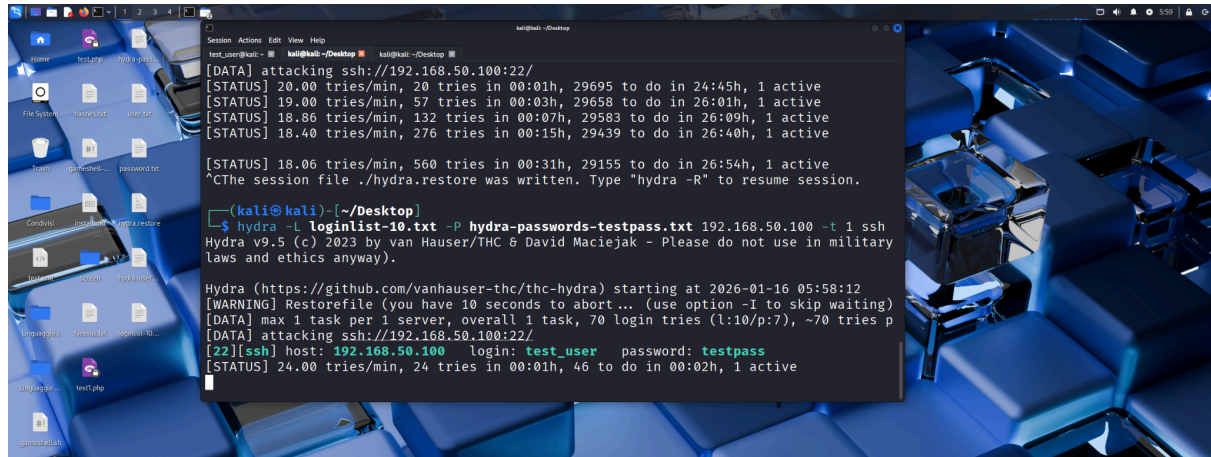
```
(kali@kali)-[~/Desktop]
$ ls
drwx----- 28 kali kali      4096 Jan 16 06:26 ..
drwxrwx--- 1 root vboxsf    20480 Jan 16 06:38 Condivisi
-rwxrwx--- 1 kali kali      226090 Dec  9 14:43 gameshell-save.sh
-rw-rw-r-- 1 kali kali      209794 Jun 17 2025 gameshell.sh
-rw-rw-r-- 1 kali kali        198 Jan 15 09:18 hashes.txt
-rw-rw-r-- 1 kali kali         78 Jan 16 05:00 hydra-passwords-testpass.txt
-rw-rw-r-- 1 kali kali      45344 Jan 16 05:01 hydra-usernames-test.cxt
-rwxr-x--- 1 kali kali        528 Aug 14 16:52 install.md
drwxrwx--- 2 kali kali      4096 Dec  2 11:06 'Linguaggio c'
drwxrwx--- 2 kali kali      4096 Dec  5 06:30 'Linguaggio python'
-rw-rw-r-- 1 kali kali        88 Jan 16 05:56 loginlist-10.txt
-rw-rw-r-- 1 kali kali       301 Jan 7 04:26 Nessus.txt
-rw-rw-r-- 1 kali kali        9 Jan 15 10:44 password.txt
drwxrwx--- 2 kali kali      4096 Dec 12 12:51 screen
-rw-r--r-- 1 root root       348 Jan 12 10:41 test1.php
-rw-r--r-- 1 root root       105 Jan 12 10:27 test.php
-rwxrwx--- 1 kali vboxsf      40 Nov 18 06:26 test.xml
-rw-rw-r-- 1 kali kali         7 Jan 15 10:44 user.txt

(test_user@kali)-[~]
$
```

Cracking SSH con Hydra

Il comando di Hydra per craccare ssh è il seguente:

hydra -L loginlist-10.txt -P hydra-passwords-testpass.txt 192.168.50.100 -t 1 ssh



```
kali@kali: ~/Desktop
[DATA] attacking ssh://192.168.50.100:22/
[STATUS] 20.00 tries/min, 20 tries in 00:01h, 29695 to do in 24:45h, 1 active
[STATUS] 19.00 tries/min, 57 tries in 00:03h, 29658 to do in 26:01h, 1 active
[STATUS] 18.86 tries/min, 132 tries in 00:07h, 29583 to do in 26:09h, 1 active
[STATUS] 18.40 tries/min, 276 tries in 00:15h, 29439 to do in 26:40h, 1 active
[STATUS] 18.06 tries/min, 560 tries in 00:31h, 29155 to do in 26:54h, 1 active
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.

(kali@kali) - [~/Desktop]
$ hydra -L loginlist-10.txt -P hydra-passwords-testpass.txt 192.168.50.100 -t 1 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military
laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-16 05:58:12
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)
[DATA] max 1 task per 1 server, overall 1 task, 70 login tries (l:10/p:7), ~70 tries p
[DATA] attacking ssh://192.168.50.100:22/
[22][ssh] host: 192.168.50.100 login: test_user password: testpass
[STATUS] 24.00 tries/min, 24 tries in 00:01h, 46 to do in 00:02h, 1 active
```

Conclusions

Nel corso dell'esercitazione è stato dimostrato come un servizio SSH configurato con autenticazione tramite password e senza adeguati meccanismi di protezione possa risultare vulnerabile ad attacchi di tipo brute-force/dictionary.

Utilizzando Hydra e wordlist mirate, è stato possibile individuare credenziali valide in un tempo limitato, evidenziando come password deboli o prevedibili rappresentino un rischio significativo per la sicurezza del sistema.

L'attacco ha avuto successo grazie alla combinazione di:

- utilizzo di password non sufficientemente robuste;
- assenza di limitazioni sui tentativi di autenticazione;
- autenticazione SSH basata esclusivamente su password.

Raccomandazioni di sicurezza

1. Disabilitare l'autenticazione tramite password e utilizzare esclusivamente l'accesso tramite chiavi SSH.
2. Limitare i tentativi di accesso tramite strumenti come *Fail2ban* per bloccare automaticamente indirizzi IP sospetti.
3. Ridurre la superficie di attacco, consentendo l'accesso SSH solo a utenti specifici tramite direttive come *AllowUsers*.
4. Cambiare la porta di default di SSH per ridurre attacchi automatici e scansioni standard.
5. Monitorare i log di autenticazione per individuare tempestivamente tentativi di accesso anomali.

In conclusione, l'esercitazione evidenzia come una configurazione sicura del servizio SSH sia fondamentale per prevenire accessi non autorizzati e come l'adozione di buone pratiche di sicurezza possa ridurre drasticamente l'efficacia di attacchi di cracking delle credenziali.

Authentication cracking con Hydra "ftp"

Come prima cosa ho installato ftp sulla macchina kali con il seguente comando:

```
sudo apt install vsftpd -y
```

Per avviarlo ho usato:

```
sudo systemctl start vsftpd
```

Poi ho abilitato il servizio:

```
sudo systemctl enable vsftpd
```

Ho verificato lo stato:

```
sudo systemctl status vsftpd
```

Infine ho verificato se il servizio FTP stava in ascolto sulla porta 21:

```
netstat -tulpn | grep :21
```

```
Session Actions Edit View Help
test_user@kali: ~
kali@kali: ~/Desktop
$ sudo systemctl start vsftpd

(kali@kali)~$ sudo systemctl enable vsftpd
Synchronizing state of vsftpd.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable vsftpd
Created symlink /etc/systemd/system/multi-user.target.wants/vsftpd.service' -> '/usr/lib/systemd/system/vsftpd.service'.

(kali@kali)~$ sudo systemctl status vsftpd
● vsftpd.service - vsftpd FTP server
   Loaded: loaded (/usr/lib/systemd/system/vsftpd.service; enabled; preset: disabled)
   Active: active (running) since Fri 2026-01-16 06:22:02 EST; 31s ago
  Invocation: 5f9071b5929e470bac3f360ced33edf
    Main PID: 60571 (vsftpd)
      Tasks: 1 (limit: 4546)
     Memory: 876K (peak: 1.8M)
        CPU: 14ms
    CGroup: /system.slice/vsftpd.service
            └─60571 /usr/sbin/vsftpd /etc/vsftpd.conf

Jan 16 06:22:02 kali systemd[1]: Starting vsftpd.service - vsftpd FTP server...
Jan 16 06:22:02 kali systemd[1]: Started vsftpd.service - vsftpd FTP server.

(kali@kali)~$ netstat -tulpn | grep :21
(Not all processes could be identified, non-owned process info
will not be shown, you would have to be root to see it all.)
tcp6      0      0  :::*          :::*          LISTEN    -

(kali@kali)~$
```

Dopo aver configurato ho effettuato l'accesso con ftp:

ftp 192.168.50.100

```
Session Actions Edit View Help
test_user@kali: ~
kali@kali: ~/Desktop
Memory: 876K (peak: 1.8M)
CPU: 14ms
CGroup: /system.slice/vsftpd.service
        └─60571 /usr/sbin/vsftpd /etc/vsftpd.conf

Jan 16 06:22:02 kali systemd[1]: Starting vsftpd.service - vsftpd FTP server...
Jan 16 06:22:02 kali systemd[1]: Started vsftpd.service - vsftpd FTP server.

(kali@kali)~$ netstat -tulpn | grep :21
(Not all processes could be identified, non-owned process info
will not be shown, you would have to be root to see it all.)
tcp6      0      0  :::*          :::*          LISTEN    -

(kali@kali)~$ ftp 192.168.50.100
Connected to 192.168.50.100.
220 (vsFTPd 3.0.5)
Name (192.168.50.100:kali): test_user
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Cracking FTP con Hydra

Il comando di Hydra per craccare ftp è il seguente:

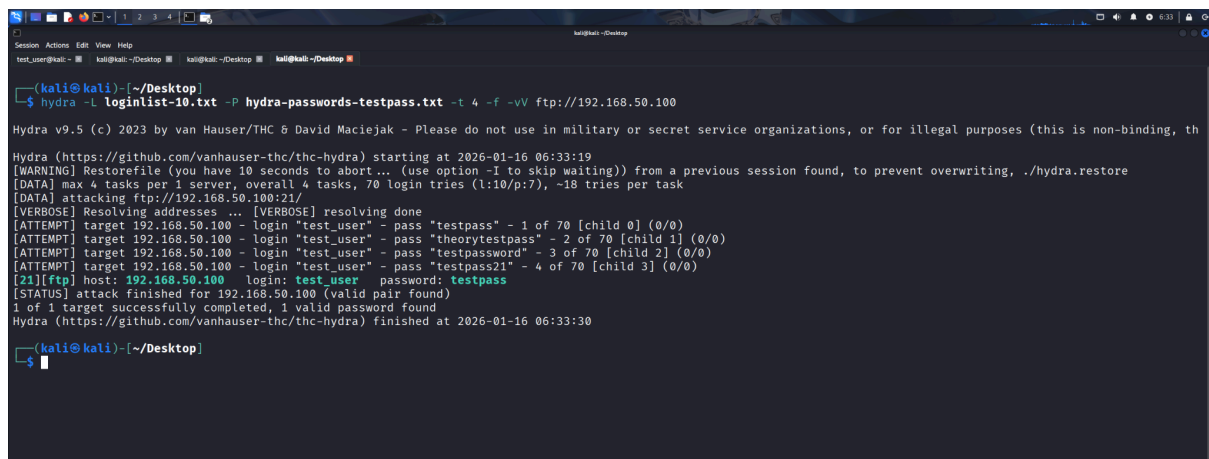
```
hydra -L loginlist-10.txt -P hydra-passwords-testpass.txt -t 4 -f -vV  
ftp://192.168.50.100
```

Questa volta con Hydra abbiamo usato 2 flag in più il `-f` e il `-vV`.

Il `-f` significa finish cioè hydra si ferma appena trova una combinazione username/password valida. Si usa per evitare tentativi inutili e riduce il tempo dell' attacco.

Il `-vV` significa Verbose ed è composto da due livelli di verbosità:

- `-v` —> mostra informazioni aggiuntive sull' attacco
- `-V` —> mostra ogni singolo tentativo di username e password provati



```
(kali@kali) [~/Desktop]
$ hydra -L loginlist-10.txt -P hydra-passwords-testpass.txt -t 4 -f -vV ftp://192.168.50.100

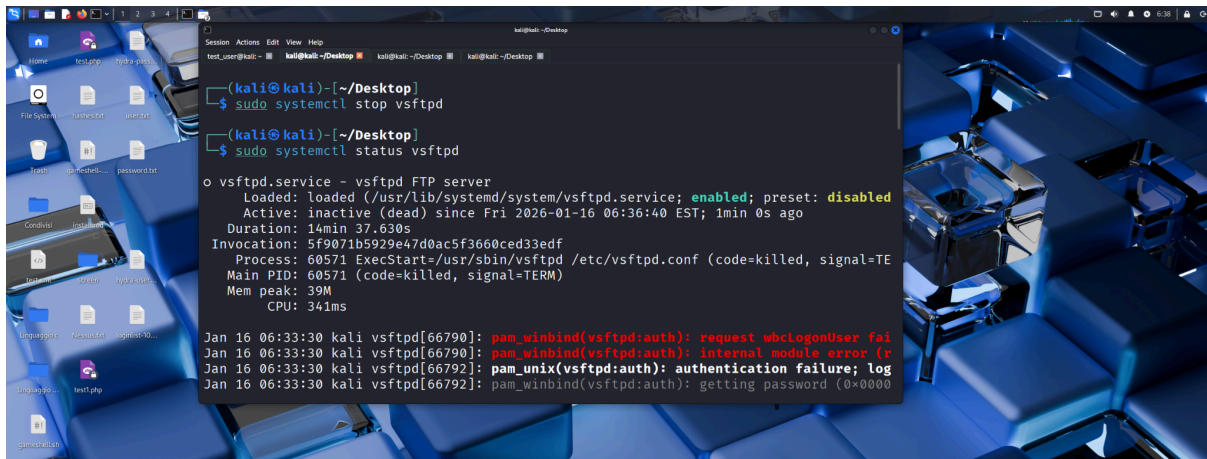
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, th

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-16 06:33:19
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 70 login tries (l:10/p:7), ~18 tries per task
[DATA] attacking ftp://192.168.50.100:21/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "testpass" - 1 of 70 [child 0] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "theorytestpass" - 2 of 70 [child 1] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "testpassword" - 3 of 70 [child 2] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "testpass21" - 4 of 70 [child 3] (0/0)
[21][ftp] host: 192.168.50.100 login: test_user password: testpass
[STATUS] attack finished for 192.168.50.100 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-16 06:33:30

(kali@kali) [~/Desktop]
$
```

Infine ho disabilitato ftp con il comando:

```
sudo systemctl stop vsftpd
```

A screenshot of a Kali Linux desktop environment. The background is a blue-themed wallpaper with a keyboard. On the left, there is a sidebar with icons for Home, Desktop, and various files. A terminal window is open in the center, showing the following commands and output:

```
(kali@kali)-[~/Desktop]
$ sudo systemctl stop vsftpd
(kali@kali)-[~/Desktop]
$ sudo systemctl status vsftpd

o vsftpd.service - vsftpd FTP server
   Loaded: loaded (/usr/lib/systemd/system/vsftpd.service; enabled; preset: disabled)
   Active: inactive (dead) since Fri 2026-01-16 06:36:40 EST; 1min 0s ago
   Duration: 14min 37.630s
   Invocation: 5f9071b5929e47d0ac5f3660ced33edf
   Process: 60571 ExecStart=/usr/sbin/vsftpd /etc/vsftpd.conf (code=killed, signal=TE
   Main PID: 60571 (code=killed, signal=TERM)
   Mem peak: 39M
   CPU: 341ms

Jan 16 06:33:30 kali vsftpd[66790]: pam_winbind(vsftpd:auth): request whcLogonUser fai
Jan 16 06:33:30 kali vsftpd[66790]: pam_winbind(vsftpd:auth): internal module error (r
Jan 16 06:33:30 kali vsftpd[66792]: pam_unix(vsftpd:auth): authentication failure; log
Jan 16 06:33:30 kali vsftpd[66792]: pam_winbind(vsftpd:auth): getting password (0x0000
```

Conclusione e raccomandazioni sulla sicurezza FTP

Nel corso dell'esercitazione è stato dimostrato come un servizio FTP configurato con autenticazione tramite password e senza adeguati meccanismi di protezione possa risultare vulnerabile ad attacchi di tipo brute-force/dictionary.

Utilizzando Hydra e wordlist mirate, è stato possibile individuare credenziali valide in un tempo molto ridotto, evidenziando come password deboli o prevedibili rappresentino un rischio significativo per la sicurezza del sistema.

L'attacco ha avuto successo grazie alla combinazione di:

- utilizzo di password non sufficientemente robuste;
- assenza di limitazioni sui tentativi di autenticazione;
- autenticazione FTP basata esclusivamente su password

Raccomandazioni di sicurezza

1. Usare password robuste per tutti gli account FTP e cambiarle periodicamente.
2. Limitare i tentativi di accesso tramite strumenti come Fail2ban o firewall che bloccano indirizzi IP dopo tentativi falliti ripetuti.
3. Consentire l'accesso FTP solo agli utenti necessari, evitando account generici o di test esposti.
4. Valutare l'uso di FTPS o SFTP (FTP su SSL/TLS o SSH) al posto di FTP plain text, per proteggere le credenziali in transito.
5. Monitorare i log di autenticazione per individuare accessi sospetti o tentativi di brute-force.

In conclusione, l'esercitazione evidenzia come un servizio FTP configurato in modo semplice e senza protezioni adeguate possa essere compromesso rapidamente tramite attacchi automatici, sottolineando l'importanza di password forti, restrizioni sugli account e monitoraggio costante.